

במפגש הרביעי של הקורס "ניהול הגנת סייבר בארגון", המרצה מיכאל השלים את נושא **התגובה לאירועים (Incident Response)** וצלח בהרחבה לעולם ה-Zero Day (פרצות יום אפס) 1. השיעור שולב בדוגמאות היסטוריות וניתוח טקטי של שלבי תקיפה והגנה. להלן סיכום הנושאים המרכזיים:

1. ניהול תגובה לאירועים (Incident Response - IR)

המהות של ה-IR היא מתן מענה מהיר ונקודתי לנטרול בעיות (פרצות או דליפות מידע) 2.

- **בעלי תפקידים בניהול אירוע:**
- **SMEs (Subject Matter Experts):** מומחי תוכן טכניים בתחומים ספציפיים כמו פיתוח, פייתון או AI 3.
- **Executive Roles:** גורמים ניהוליים המובילים את הטיפול במשבר ומקבלים החלטות חותכות, כמו ניתוק סגמנטים ברשת 4, 5.
- **Business Roles:** אנשי עסקים המנתחים את הנזק הכלכלי, האימפקט על הלקוחות והפיצויים הנדרשים (לדוגמה, חברת EMC שילמה בעבר 2.5 מיליון דולר ליום על השבתת מערכות) 4, 6.
- **רמות חומרה (Severity):**
- **Sev 4-3:** אירועים קלים (דליפות קטנות, בעיות קוסמטיות). הטיפול שוטף ויכול להימשך זמן רב (עד 120 יום) 7-10.
- **Sev 2:** אירועים המשפיעים על העבודה השוטפת, פתרון תוך 30-60 יום 11, 12.
- **Sev 1:** אירוע קריטי (פריצה לפרודקשן). דורש מעורבות של **Crisis Manager** (מנהל משברים) וכל הדרגים הבכירים לטיפול מיידי 12, 13.

2. עולם ה-Zero Day

פרצת יום אפס היא חולשה חדשה שטרם נודעו לה פתרון או הגנה 14.

- **מושגי יסוד:** **Vulnerability** (החולשה עצמה), **Exploit** (הקוד המנצל אותה) ו-**Attack** (התקיפה בפועל) 15.
- **לוחות זמנים:** הסטנדרט בתעשייה הוא כ-30 יום לגילוי החולשה על ידי הארגון ועד 45 יום להוצאת תיקון (Patch). חלון החשיפה המסוכן ביותר הוא בין רגע הגילוי על ידי התוקף ועד שהארגון מבצע פעולה 16, 17.
- **סטטיסטיקה:** בארגונים גדולים יש אלפי חולשות חדשות בחודש, אך פחות מ-1% מהן באמת בעלות השפעה או חשיפה חיצונית קריטית 17, 18.
- **מי מוצא פרצות?** האקרים (לטובת פרסום או כופר), חוקרים עצמאיים המקבלים תגמול (Bug Bounty), חברות אבטחה (כמו Wiz) וגופי בין למטרות ריגול 19-23.

3. מחזור חיים של מתקפה ודרכי פעולה

- מתקפה טיפוסית מורכבת מארבעה שלבים: **גילוי** (באמצעות סריקות אוטומטיות), **חימוש** (כתיבת האקספלויט), **פשינג** (החדרת הקוד לארגון) ושימוש ב-**Backdoor** (דלת אחורית) 24, 25.
- **העלאת הרשאות (Privilege Escalation):** התוקף מנסה להגדיל את כוחו במערכת:
 - **אנכי (Vertical):** ניסיון להפוך למשתמש חזק יותר (אדמיניסטרטור) 26.
 - **אופקי (Horizontal):** השתלטות על משתמשים באותה רמה לצורך גניבת זהות או מידע פרטי 26, 27.
 - **דוגמאות בולטות:** **Stuxnet** (תקיפת הצנטריפוגות באיראן), **WannaCry** (תוכנת כופר שפגעה בעשרות אלפי מחשבים), **SolarWinds** (חדירה לתשתיות ניהול רשתות) ו-**Movelit** (דליפת מידע עקב 28-35 SQL Injection).

4. אסטרטגיות הגנה מודרניות

המרצה הסביר מדוע פיירוולים מסורתיים (המחפשים דפוסים מוכרים) כבר אינם מספיקים מול איומים דינמיים מבוססי AI 36, 37.

- **Sandbox (ארגז חול):** סביבה מבודדת ומנותקת מהפרודקשן המאפשרת להריץ קוד חשוד ולראות את השפעתו ללא נזק לארגון 38, 39.
- **Honeypot (מלכודת דבש):** סביבה המדמה את המערכת האמיתית אחד-לאחד במטרה למשוך תוקפים. הארגון עוקב אחרי התוקף כדי ללמוד את שיטותיו (Hunt) ואף יכול לתקוף אותו בחזרה בצורה פרו-אקטיבית 39-42.

לוגיסטיקה (לגבי המבחן):

- המבחן יהיה **אמריקאי**, יכלול כ-33 שאלות ויימשך 70 דקות 10, 43.
- במפגש האחרון יתבצע מיקוד ויינתן מבחן לדוגמה 43.
- סטודנטים מגויסים יכולים לבחור בין הגשת מטלה (כ-4 שאלות עם סעיפים) לבין ביצוע המבחן 11, 43.